

Siber Tehdit İstihbaratı Brifingi

Yönetici Özeti

Siber Tehdit İstihbaratı (CTI), modern Güvenlik Operasyonları Merkezleri (SOC) için vazgeçilmez bir unsurdur; ham verileri ve uyarıları, bir kuruluşun tehditlere karşı proaktif olarak savunma yapmasını sağlayan, bağlamsal ve eyleme geçirilebilir içgörülere dönüştürür. Bu süreç, tehdit aktörlerini, onların taktiklerini, tekniklerini ve prosedürlerini (TTP'ler) ve potansiyel hedeflerini anlamaya odaklanır. Etkili bir CTI programı, altı aşamalı bir yaşam döngüsünü takip eder: Yönlendirme, Toplama, İşleme, Analiz, Yayma ve Geri Bildirim. Bu döngü, istihbaratın kuruluşun özel riskleri ve savunma yetenekleriyle uyumlu olmasını sağlar. Temel analiz, iki ana gösterge türü etrafında yoğunlaşır: ağ tabanlı (IP adresleri ve alan adları) ve dosya tabanlı (dosya yolları ve hash'ler). Ağ göstergelerinin zenginleştirilmesi, DNS kayıt analizi, RDAP aracılığıyla sahiplik tespiti, Otonom Sistem Numarası (ASN) bağlamı, TLS sertifika incelemesi ve itibar servisleri (VirusTotal gibi) ile pasif DNS geçmişi gibi teknikleri içerir. Dosya göstergelerinin analizi ise, saldırgan davranışlarını ortaya çıkaran dosya yolları ve adlandırma sezgileri gibi statik özellikleri ve sanal alan (sandbox) ortamlarında yürütme yoluyla davranışsal etkileri ortaya çıkaran dinamik analizleri kapsar. MITRE ATT&CK, D3FEND ve Siber Ölüm Zinciri (Cyber Kill Chain) gibi çerçeveler, tehditleri ve savunma stratejilerini sınıflandırmak için ortak bir dil ve yapı sunar. Bu araçlar, analistlerin gözlemlenen davranışları standartlaştırılmış taktiklerle eşleştirmesine, olay müdahalesini hızlandırmasına ve savunma kontrollerini güçlendirmesine olanak tanır. Sonuç olarak, CTI, SOC'lerin reaktif uyarı yönetiminden, tehditleri önceden tahmin edip etkisiz hale getiren stratejik bir savunma duruşuna geçmesini sağlar.

Bölüm 1: Siber Tehdit İstihbaratının (CTI) Temelleri

Siber Tehdit İstihbaratı, bir SOC analistinin yüzlerce uyarı arasından hangisinin gerçek bir tehlikeyi temsil ettiğine karar vermesine yardımcı olan bağlamı sağlar. Güvenilir bağlamla, SOC enerjisini doğru konulara harcar. CTI, üç temel soruyu yanıtlamayı amaçlar:

1. Bu uyarı göstergesinin diğer ucunda kim veya ne var?
2. Geçmişteki davranışları neydi?
3. Kuruluşum nasıl yanıt veriyor ve şu anda ne yapmalıyım? Bu soruların erken aşamada, tercihen dakikalar içinde yanıtlanması, olay müdahale (IR) ekibi için değerli zaman kazandırır.

Veriden İstihbarata

Güvenlik literatürü **veri**, **bilgi** ve **istihbaratı** ayırt eder. Bu terimlerin netleştirilmesi, bir analistin hedefini belirginleştirir. Seviye 1 analisti, eserleri (artefacts) kullanılabilir hale getirmekten ve onları istihbarat niteliği kazanana kadar zenginleştirmekten sorumludur. Bu zenginleştirme süreci; köken, davranış ve alaka düzeyi hakkında ışık tutan halka açık, ticari ve dahili kaynakların hızlı ve metodik olarak incelenmesiyle gerçekleştirilir. | Katman | Tanım | Uyarı Kuyruğu Örneği | SOC L1 Eylemi || ----- | ----- | ----- || **Veri** | İşlenmemiş bir gözlemlenebilir | 45.155.205.3 :443 | Eseri yakala. || **Bilgi** | Veri artı olgusal ek açıklama | *IP, Hetzner'e kayıtlı, ilk görülme 2023-07-14* | Nitelikleri kaydet. || **İstihbarat** | "*Peki ne olmuş?*" sorusunu yanıtlayan analiz edilmiş bilgi | *IP mevcut BumbleBee C2'ye ait; derhal engelle* | Yükselt veya bastır. |

Bu süreçte analistler için üç temel etiket öne çıkar:

- **Saldırı Göstergesi (Indicator of Compromise - IOC):** Bir ihlalin kanıtı, örneğin loglarda bir Komuta ve Kontrol (C2) adresi.
- **Saldırı Belirtisi (Indicator of Attack - IOA):** Devam etmekte olan kötü niyetli bir eylem, örneğin PowerShell'in bilinmeyen bir hizmet başlatması.
- **Taktikler, Teknikler ve Prosedürler (TTP):** Bir düşmanın MITRE ATT&CK kimlikleri ve açıklamalarıyla ifade edilen ayrıntılı metodolojileri.

İstihbarat Sınıflandırmaları

Tehdit istihbaratı, operasyonel ortam ile düşman arasındaki ilişkiyi anlamaya yöneliktir ve dört ana sınıfa ayrılır:

- **Stratejik İstihbarat:** Kuruluşun tehdit ortamına üst düzeyden bakar ve iş kararlarını etkileyebilecek eğilimlere, kalıplara ve ortaya çıkan tehditlere dayalı risk alanlarını haritalandırır.
- **Taktiksel İstihbarat:** Düşmanların TTP'lerinin analizi yoluyla davranışlarının değerlendirilmesidir. Örneğin, kötü amaçlı spam'lerde yeni T1059.005 (Visual Basic) kötüye kullanımını detaylandıran danışma notları.
- **Operasyonel İstihbarat:** Bir saldırıyı gerçekleştirme motivasyonları ve niyetleri hakkında kampanyaya özgü ayrıntılardır.
- **Teknik İstihbarat:** Bir saldırıyla ilişkili IP'ler ve hash'ler gibi atomik göstergeler ve eserlerdir. L1 analistleri çoğunlukla Teknik IOC'leri yükseltir, Taktiksel IOA'ları gözlemler ve belgeler.

Temel Gösterge Türleri

Her eser, özel bir zenginleştirme yolu gerektirir. Analistlerin, uyarının hangi tür gösterge sağladığını tanıması ve nereye bakacağını bilmesi önemlidir. | Gösterge | Örnek | İlk Kaynaklar | İlişkili IOA veya TTP Örnekleri || ----- | ----- | ----- | ----- || **IPv4 / IPv6** | 45.155.205.3 | • WHOIS (ASN, tahsis tarihi) • VirusTotal ilişkileri • Shodan banner taraması | IOA: Tekrarlanan SSH başarısızlıkları, TTP: T1110.003 Parola Tahmini || **Alan Adı / FQDN** | malicious-updates.net | • WHOIS yaşı • RiskIQ veya SecurityTrails pasif DNS • urlscan.io | IOA: 24 saatlik bir alan adına yönelik DNS sorgularında ani artış || **URL** | hxxp://malicious-updates.net/login | • URLhaus itibarı • urlscan.io davranış grafiği • Any.Run dinamik çalıştırma | IOA: /gateway.php'ye yük içeren tarayıcı POST işlemi || **Dosya hash'i** | e99a18c428cb38d5... | • VirusTotal statik & dinamik • Hybrid-Analysis • MalShare arşivi | TTP: T1055 regsvr32.exe içine Proses Enjeksiyonu || **E-posta adresi** | billing@evil-corp.com | • MXToolbox başlık analizi • Have I Been Pwned | IOA: SPF hatası artı yeni alan adı kaydı || **Yerel eser** | HKCU\Software\Run\updater.exe | • Sigma kuralları • EDR yaygınlık sorgusu • Satıcı bilgi tabanları | TTP: T1060.001 Kayıt Defteri Çalıştırma Anahtarları |

Bölüm 2: Siber Tehdit İstihbaratı Yaşam Döngüsü

TryHatMe Corp senaryosu, CTI yaşam döngüsünün altı adımını pratik bir örnekle açıklamaktadır. Kuruluş, PostgreSQL veritabanını korumak için CTI'yi entegre etmeyi amaçlamaktadır.

Adım 1: Yönlendirme – Görevin Tanımlanması

Bir L1 analisti olan Alex, CTI lideri ve veritabanı yöneticisiyle birlikte, "CTI'yi entegre etme" genel hedefini ölçülebilir sorulara dönüştürür:

- S1: Şu anda PostgreSQL hizmetlerini istismar etmek veya veritabanı kayıtlarını sızdırmak için hangi harici IP adresleri ve alan adları kullanılıyor?
- S2: Bu hafta PostgreSQL sürücülerini veya kimlik bilgilerini hedef alan hangi kötü amaçlı yazılım aileleri aktif ve dosya hash'leri nelerdir?

Adım 2: Toplama – Ham Materyalin Birleştirilmesi

Alex, bu sorulara yanıt bulmak için çeşitli kaynaklardan veri toplar: | Kaynak | Gerekçe | Toplanan Örnek Eserler || ----- | ----- | ----- || **Ticari besleme** (NGFW satıcısından) | Aynı güvenlik duvarı modellerine özel, yüksek doğruluk | Son 24 saatte veritabanı sızdırma C2'si olarak işaretlenen 37 IPv4 adresi || **Açık kaynak projesi** (*AbuseIPDB*) | Hızlı, topluluk odaklı güncellemeler | *PostgreSQL-brute-force* etiketiyle filtrelenmiş 15 IP adresi, dört alan adı || **MISP** (şirket içi) | Olayların tarihsel görünümü | PgSQL kimlik bilgisi çarplarının 2 SHA-256 hash'i || **Satıcı tehdit raporu** | Stratejik içgöründen teknik IOC'lere | 1 yeni kötü amaçlı yazılım hash'i, 3 C2 alan adı |

Adım 3: İşleme – Verilerin Normalleştirilmesi ve İlişkilendirilmesi

Ham beslemelerdeki veriler standartlaştırılır. Alex'in Python betikleri gösterim biçimlerini normalleştirir (örneğin, alan adlarını küçük harfe çevirir), mevcut göstergelerle karşılaştırarak tekilleştirir ve her girdiyi kaynak ve tarihle etiketler.

Adım 4: Analiz – Bilgiyi Yargıya Dönüştürme

Toplanan istihbaratın kuruluşla ilgisi değerlendirilir. Alex, bir Splunk sorgusuyla NGFW beslemesindeki bir IP'nin üretim ağına erişmeye çalıştığını doğrular. Her gösterge, güvenilirlik seviyesine göre derecelendirilir. | Güvenilirlik | Kaynak Uyumu | Yerel Görülme | Eylem || ----- | ----- | ----- || **Yüksek** | Aynı IOC ≥ 2 kaynakta | ≥ 1 yerel deneme | Anında engelleme || **Orta** | Tek güvenilir kaynak | Yerel isabet yok | Sadece uyarı || **Düşük** | Sadece OSINT | Bağlam yok | 14 gün izleme |

Adım 5: Yayma – İstihbaratın Doğru Tüketicilere Ulaştırılması

Analiz sonuçları, her paydaşın ihtiyacına göre uyarlanmış formatlarda sunulur. | Paydaş | Format | Neden İhtiyaç Duyuyorlar || ----- | ----- | ----- || **Güvenlik duvarı ekibi** | CSV yükleme + değişiklik bileti | Engelleme kurallarından sorumlular; bilet riski belgeler || **Uç nokta ekibi** | EDR konsolunda YARA kural seti | Kuralları politikaya yüklemek için || **CTI platformu** | Tam etiketli gösterge nesneleri | Eserlerin geçmişini tutar, gelecekteki ilişkileri destekler || **Yönetim** | Haftalık siber risk notunda 200 kelimelik özet | Sürecin yatırım getirisini gösterir |

Adım 6: Geri Bildirim – Döngünün Ölçülmesi ve İyileştirilmesi

İki hafta sonra, uygulanan kontrollerin etkinliği ölçülür. Başarı metrikleri (KPI'lar), CTI sürecinin etkinliğini gösterir. Örneğin, PostgreSQL kaba kuvvet saldırılarının ortalama bekleme süresi 48 saatten 0'a düşmüştür. Bu başarı, sürecin genişletilmesi için onay alınmasını sağlar.

Bölüm 3: Ağ Tabanlı Göstergelerin Analizi: IP'ler ve Alan Adları

Ağ tabanlı tehdit istihbaratı, modern siber güvenlik savunmasının temel bir yönüdür. IP adresleri ve alan adları, bir SOC analistinin triyaj kuyruğundaki en yaygın göstergelerdir.

DNS Zenginleřtirmesi

Alan Adı Sistemi (DNS), internetin kullanılabilirlięindeki merkezi rolü nedeniyle saldırganlar için popüler bir oyun alanıdır. SOC analistleri için DNS, en zengin erken uyarı veri setlerinden biridir. Bir alan adını zenginleřtirirken en önemli kayıtlar řunlardır:

- **A / AAAA Kayıtları:** Alan adını IPv4 ve IPv6 adreslerine eřler. Sık sık deęiřen A kayıtları řüphe uyandırır.
- **NS Kayıtları:** Alan adını kontrol eden ad sunucularını belirtir. Olaęandışı veya yakın zamanda deęiřtirilmiř NS giriřleri, yeni bir kurulumu iřaret edebilir.
- **MX Kayıtları:** E-postayı hangi sunucuların yöneteceęini tanımlar.
- **TXT Kayıtları:** SPF ve DKIM kurallarını veya doęrulama etiketlerini saklar.
- **SOA Kaydı:** Bölgenin birincil yetkilisini gösterir ve genellikle iletiřim bilgilerini içerir.
- **TTL (Yařam Süresi):** Çözümleyicilere yanıtları ne kadar süreyle önbelleęe alacaklarını söyler. Çok düşük TTL'ler sık deęiřikliklere iřaret edebilir.

DNS Kullanan Saldırı Teknikleri

- **Fast Flux Barındırma:** Saldırganlar, basit engellemelerden kaçınmak için birçok IP'yi kısa önbellek süreleriyle hızla döndürür.
- **CDN Kötüye Kullanımı:** Meřru CDN'ler de IP'leri deęiřtirir, ancak kendi ASN ekosistemleri içinde. A kaydı büyük bir CDN'i gösteriyorsa, itibar ve sahiplik kontrolleri yapılmalıdır.
- **Yazım Hatasıyla Alan Adı İşgali (Typosquatting):** paypa1.com gibi alan adları kullanıcıları görsel olarak aldatır.
- **IDN (Uluslararasılařtırılmıř Alan Adları):** Saldırganlar, Unicode'u kullanarak benzer görünümlü alan adları oluřturur.

IP Zenginleřtirmesi

Bir IP adresi tek başına belirsizdir. **Zenginleřtirme** , bir IP'ye sahiplik, ASN, coęrafi konum ve hizmet baęlamı ekleyerek kararların kanıta dayalı olmasını saęlar.

- **RDAP (Kayıt Veri Eriřim Protokolü):** IP sahiplięi için yetkili kaynaktır. **NetRange** (tahsis edilen adres aralıęı) ve **Kuruluř** (kayıtlı sahip) gibi bilgiler saęlar.
- **Otonom Sistemler (AS):** Tek bir kuruluřun kontrolü altındaki IP önekleri koleksiyonudur. ASN'ye bakmak, bir IP'nin olası rolünü deęerlendirmeye yardımcı olur:
- **Barındırma ASN'leri:** Genellikle řüpheli alan adlarının barındırıldıęı yerler.
- **Konut İnternet Saęlayıcıları (ISP'ler):** Milyonlarca kullanıcıyı kapsayan devasa aralıklar.
- **Bulut/CDN ASN'leri:** Küresel, paylařılan altyapı. Bu aralıkların tamamen engellenmesi büyük yan hasara neden olabilir.

Servis, Sertifika, İtibar ve Geçmiř Analizi

- **Servis Keřfi:** Shodan ve Censys gibi araçlar, bir IP'de açık olan portlar ve çalışan servisler hakkında ayrıntılı bilgi saęlayarak sistemin amacını ve potansiyel risklerini ortaya çıkarır.
- **TLS Sertifika Şeffaflıęı:** crt.sh gibi araçlar, herkese açık olarak güvenilen her sertifikayı günlüęe kaydeder. İncelenecek önemli alanlar řunlardır: **Veren Kuruluř** (örn. Let's Encrypt), **Geçerlilik Süresi** (kısa ömürlü sertifikalar normaldir) ve **Konu Alternatif Adları (SAN'lar)** (sertifikanın kapsadıęı tüm alan adları).

- **İtibar Servisleri:** VirusTotal ve Cisco Talos gibi hizmetler, bir göstergenin tespit oranı, kategorisi ve topluluk notları hakkında bilgi sağlar.
- **Pasif DNS:** Alan adlarının zaman içinde nasıl çözümlendiğine dair tarihsel bir kayıt sunar. **İlk Görülme/Son Görülme** tarihleri, alan adının yeni mi yoksa uzun ömürlü mü olduğunu gösterir.

SOC Analist İş Akışı Özeti

1. **VirusTotal, Cisco Talos ve IP2Proxy'yi kontrol et:** Tespit oranını, itibarı, kategoriyi ve proxy/VPN kullanımını kaydet.
2. **Pasif DNS'i kontrol et:** İlk/son görülme tarihlerini, son 7 gündeki IP sayısını ve ASN dağılımını kaydet.
3. **Shodan/Censys'i kontrol et:** Açıkta kalan servisleri ve olası yanlış yapılandırmaları belirle.
4. **TLS sertifikalarını incele:** Veren kuruluşu, SAN'ları ve geçerlilik süresini kaydet. Şüpheli kalıpları (örneğin, marka taklitleri) ara.
5. **CT Günlükleri ve Wayback Machine'i çapraz kontrol et:** Sertifika oluşturma yoğunluğunu ve içerik değişikliklerini (örneğin, zararsızdan olumsuz sitesine dönüşüm) belirle.
6. **Karar ver:** Gözlemlenen aktiviteye bağlı olarak engelle, izle veya kapat.

Bölüm 4: Dosya Tabanlı Göstergelerin Analizi: Dosyalar ve Hash'ler

Güvenlik Operasyonları ekipleri için temel iş akışı üç adımdan oluşur: **doğrula** , **zenginleştir** ve **karar ver** . Dosya ve hash istihbaratı, zenginleştirme aşamasında kritik bir rol oynar.

Statik Analiz

Dosya Yolu Analizi

Dosya yolları ve adları, saldırgan davranışları hakkında ipuçları verir. Saldırganlar eylemlerini gizlemek için belirli disk konumlarını kullanabilirler:

- C:\Users\Public: Kullanıcılar arası erişim sağlamak için.
- C:\Users\Public\Public Downloads: Sıkı izlemeden kaçınmak için yüksek trafikli bir dizin.
- C:\Windows\Temp: Geçici yükler için.
- C:\ProgramData: Gizli kalıcılık için yazılabilir sistem yolları.

Dosya Adı Sezgisel Göstergeleri

Saldırganlar, tespitten kaçmak için dosya adlarını değiştirirler:

- **Çift uzantı:** invoice.pdf.exe gibi, Windows'un varsayılan olarak dosya uzantılarını gizlemesinden yararlanır.
- **Sistem ikili dosyası taklidi:** scvhost.exe gibi, kullanıcının temel sistem süreçlerine olan aşinalığını kötüye kullanır.
- **Yüksek entropili dizeler:** jh8F21.exe gibi, otomatik paketleme veya polimorfik üretimi düşündürür.
- **Maskeleye:** backup-2300.exe gibi, rutin dosyalarla karışarak şüpheliyi azaltır.

Kriptografik Hash'lerin Rolü

Dosya adları sürekli değişse de, bir dosyanın **SHA256** veya **MD5** gibi kriptografik hash'i değişmez. Hash'ler, dosya adından bağımsız olarak kötü amaçlı yazılımları kesin olarak tanımlamak için değişmez ve eyleme geçirilebilir bir yol sağlar.

Dinamik Analiz ve Sandbox Kullanımı

Bir dosyanın kimliğini anlamak için statik özellikler yeterlidir, ancak etkisini anlamak için onu güvenli, kontrollü bir ortamda yürütmek gerekir. **Sandbox'lar**, kötü amaçlı yazılımla ilişkili her işlemi, kayıt defteri yazmasını ve ağ paketini yakalamak için donatılmış tek kullanımlık sanal makineler sağlar. Güvenlik analistleri sandbox'ları şu üç amaçla kullanır:

1. **Yürütmeyi onayla:** Hiçbir şey olmazsa, uyarı bir yem olabilir.
2. **Çalışma zamanı IOC'lerini çıkar:** Alan adları, mutex'ler, bırakılan yükler gibi avcılık ve tespit için veri sağlar.
3. **ATT&CK ile eşleştir:** Çoğu sandbox, davranışı otomatik olarak teknik kimliklerle etiketleyerek raporlamayı hızlandırır.

Sandbox Araçları ve Sınırlamaları

1. **Araçlar:** **Hybrid Analysis** (davranış ağaçları ve MITRE ATT&CK ısı haritası ile hızlı özetler için uygun) ve **Joe Sandbox** (sistem çağrıları, dizeler ve bellek dökümleri ile derinlemesine analiz için).
2. **Sınırlamalar:**
3. **Sandbox'tan Kaçınma Teknikleri:** Kötü amaçlı yazılımlar sanallaştırılmış ortamları algılayıp normal davranarak yanlış negatiflere yol açabilir.
4. **Sınırlı Yürütme Süresi:** Çoğu sandbox analizi 2-5 dakika sonra sonlandırır, bu da çok aşamalı veya zaman gecikmeli saldırıların tam olarak yürütülmesini engelleyebilir.
5. **Şifreli ve Gizlenmiş Trafik:** Birçok sandbox, SSL/TLS trafiğinin şifresini çözemez, bu da C2 iletişiminin görünmez kalmasına neden olabilir.
6. **Dosyasız ve "Living-off-the-Land" (LotL) Kötü Amaçlı Yazılımları:** Bazı tehditler diske hiç dokunmaz, PowerShell saldırıları ve WMI kalıcılığı gibi yöntemlerle geleneksel sandbox analizini atlar.

Bölüm 5: Temel Çerçeveler ve Standartlar

MITRE ATT&CK ve D3FEND

- **MITRE ATT&CK:** Düşman davranışları hakkında bilgi sağlayan bir bilgi tabanıdır. T1059.001 PowerShell gibi her teknik, satıcılar, ekip arkadaşları ve denetçiler arasında ortak bir dil görevi görür. Bir L1 analisti, bir uyarıdaki davranışı bir ATT&CK tekniğiyle eşleştirerek olayı daha üst seviyelere hızlı ve net bir şekilde iletebilir.
- **MITRE D3FEND:** ATT&CK'in savunma tarafındaki karşılığıdır. Savunucuların nasıl yanıt verdiğini kataloglar. Bir saldırı tekniği (örneğin, T1048.003 DNS tüneli) tespit edildiğinde, D3FEND ilgili savunma tekniğini (D3—NTDN DNS—istek analizi) ve pratik kontrolleri listeler.

Siber Ölüm Zinciri (Cyber Kill Chain)

Lockheed Martin tarafından geliştirilen bu model, bir saldırının aşamalarını ayırır. Bu, analistlerin bir saldırıyı araştırırken hangi aşama faaliyetlerinin gerçekleştiğini belirlemesine

yardımcı olur. | Aşama | Amaç | Örnekler || ----- | ----- | ----- || **Keşif** | Kurban ve saldırı taktikleri hakkında bilgi toplama. | E-posta toplama, OSINT, ağ taramaları || **Silahlanma** | Kötü amaçlı yazılımın saldırının ihtiyaçlarına göre tasarlanması. | Arka kapılı bir istismar, kötü amaçlı Office belgesi || **Teslimat** | Kötü amaçlı yazılımın kurbanın sistemine nasıl ulaştırılacağı. | E-posta, web bağlantıları, USB || **Sömürü** | Kod çalıştırmak ve kalıcılık sağlamak için sistem güvenlik açıklarından yararlanma. | EternalBlue, Zero-Logon || **Kurulum** | Kurbanın sistemine erişim sağlamak için kötü amaçlı yazılım yükleme. | Parola dökümü, arka kapılar, uzaktan erişim truva atları || **Komuta & Kontrol** | Ele geçirilen sistemi uzaktan kontrol etme, ek kötü amaçlı yazılım dağıtma. | Empire, Cobalt Strike || **Hedefler Üzerinde Eylemler** | Saldırının amaçlarını gerçekleştirme: finansal kazanç, veri sızdırma vb. | Veri şifreleme, fidye yazılımı |

Zafiyet Yönetimi ve Paylaşım Standartları

- **CVE (Common Vulnerabilities and Exposures):** Keşfedilen güvenlik açıklarına bir katalog numarası sağlar.
- **CVSS (Common Vulnerability Scoring System):** Güvenlik açıklarına 0-10 arası bir ciddiyet ölçeği atar.
- **NVD (National Vulnerability Database):** CVE numaralarını CVSS puanları, istismarlar ve etkilenen ürünlerle ilişkilendiren merkezi depodur.
- **STIX ve TAXII:**
- **STIX:** Tehdit bilgilerini tanımlamak için yapılandırılmış bir JSON şemasıdır.
- **TAXII:** Tehdit istihbaratını neredeyse gerçek zamanlı olarak değiş tokuş etmek için kullanılan bir dizi güvenli API'dir. Bu standartlar, kuruluşların istihbaratı verimli bir şekilde paylaşarak kolektif savunmayı güçlendirmesini sağlar.